

Auditoria tecnica-funcional de cumplimiento

Encipharm Ventas | Contraste de implementacion real contra especificacion oficial consolidada

Resultado ejecutivo: el repositorio esta listo para demo tecnica y Development, pero no esta listo para QA formal, UAT ni produccion. Existe un MVP web funcional parcial con FastAPI, Firestore, Firebase Auth y React/Vite; el alcance oficial completo exige componentes no implementados como Vue/Pinia, Flutter, RAG Vertex/Gemini, ERP/SAP, Google Calendar/Meet, multi-tenancy, feature gating y reportes exportables.

Verificacion	Resultado
Backend tests	uv run pytest: 67 passed
Frontend lint	npm.cmd run lint: OK
Frontend build	npm.cmd run build: OK
PDF	Generado con ReportLab y validado con pypdf

Indice del informe

#	Seccion
1	Resumen ejecutivo
2	Alcance auditado
3	Inventario del repositorio
4	Arquitectura detectada vs arquitectura esperada
5	Matriz maestra de requerimientos
6	Cumplimiento por modulos
7	Evaluacion de roles y permisos
8	Evaluacion de API
9	Evaluacion de no funcionales y estandares transversales
10	Inconsistencias entre documentacion y codigo
11	Riesgos actuales del proyecto
12	Que ya esta
13	Que esta parcial
14	Que falta
15	Que hay que pulir
16	Que cumple con el cliente
17	Que no cumple con el cliente
18	Backlog priorizado de cierre
19	Recomendacion final sobre estado del sistema

1. Resumen ejecutivo

El sistema implementado cubre parte del MVP web: login Google, validacion de token en backend, sincronizacion de usuario, clientes CRUD, importacion CSV backend, interacciones, oportunidades, propuestas basicas, dashboard comercial y administracion parcial de usuarios. La brecha principal es de alcance y arquitectura: la especificacion oficial describe una plataforma multi-cliente, web Vue, mobile Flutter, IA RAG, ERP/SAP, Calendar/Meet, Storage y observabilidad productiva; el codigo real implementa una variante web acotada en React.

Clasificacion: listo para demo; no listo para QA formal, UAT ni produccion.

2. Alcance auditado

- Auditado: Backend FastAPI, frontend React/Vite, documentacion, tests, reglas Firestore, configuracion Firebase/Vercel y carpeta mobile.
- No auditado como funcional: servicios externos no presentes en el codigo, credenciales reales, ambientes Cloud Run, PR aprobados o ceremonias Scrum.
- Fuente de verdad funcional: especificacion textual entregada por el cliente en este hilo.

3. Inventario del repositorio

Area	Evidencia	Estado
Backend	Backend/app/main.py, app/api, app/services, app/models	Implementado
Frontend	frontend/src/App.jsx, services/api.js, auth/AuthProvider.jsx	Implementado en React
Firestore rules	firestore.rules: allow read, write false	Bloqueo total a cliente directo
Docs	docs/api, docs/qa, docs/sprints, architecture.md	Amplia, con inconsistencias
Tests	Backend/tests	67 tests backend pasando
Mobile	mobile/	Carpeta vacia/reservada
Infra	firebase.json, vercel.json	Parcial; sin Cloud Build

4. Arquitectura detectada vs arquitectura esperada

Capa	Esperado oficial	Detectado	Estado
Web	Vue 3, Vite, Pinia	React 19 + Vite	Implementado pero desalineado
Mobile	Flutter iOS/Android	mobile vacio	No cumple
Backend	FastAPI Cloud Run	FastAPI modular	Cumple parcial
Auth	Firebase Auth + Admin	Implementado	Cumple
DB	Firestore	Firestore via Admin SDK	Cumple parcial
Storage	Adjuntos, PDF, corpus RAG	Solo variables/config	No cumple
IA	Vertex/Gemini RAG	Pantalla no operativa	No cumple/Fase 2
ERP/SAP	REST/SOAP	Ausente	No cumple/Fase 2
Calendar/Meet	API real	Modal no operativo	No cumple/Fase 2

5. Matriz maestra de requerimientos

ID	Categoria	Requerimiento	Criticidad	Estado
R01	Stack	Vue 3 + Pinia	Alta	No cumple

ID	Categoria	Requerimiento	Criticidad	Estado
R02	Stack	React no estaba en alcance oficial	Alta	Implementado pero desalineado
R03	Backend	FastAPI	Alta	Cumple
R04	Auth	Firebase Auth Google SSO	Critica MVP	Cumple
R05	Auth	Validacion ID token backend	Critica MVP	Cumple
R06	Roles	Rol desde Firestore users	Critica MVP	Cumple
R07	CRM	Clientes CRUD + busqueda	Critica MVP	Cumple parcialmente
R08	CRM	BANT editable/auditado	Alta	No cumple
R09	CRM	Historial compras ERP	Alta	No cumple
R10	CRM	Export PDF ficha	Media	No cumple
R11	CRM	Import CSV admin	Critica MVP	Cumple
R12	Visitas	Registro interacciones/visitas web	Critica MVP	Cumple parcialmente
R13	Visitas	GPS, check-in/out, adjuntos	Alta	No cumple
R14	Propuestas	Propuesta ligada a oportunidad	Critica MVP	Cumple parcialmente
R15	Propuestas	PDF, versiones, motivo perdida	Alta	No cumple
R16	Pipeline	Oportunidades CRUD/lista	Critica MVP	Cumple parcialmente
R17	Pipeline	Historial de etapa	Alta	No cumple
R18	Dashboard	Vendedor/supervisor	Critica MVP	Cumple parcialmente
R19	Dashboard	Alertas por vencimiento/inactividad	Alta	No cumple
R20	RAG	Chat Gemini con citas	Fase 2	No cumple
R21	Competencia	Lectura comparativa	Fase 2	Cumple parcialmente
R22	Reportes	XLSX/PDF	Alta	No cumple
R23	Mobile	Flutter app	Fase 2	No cumple
R24	Transversal	Multi-tenancy	Alta	No cumple
R25	Transversal	Feature gating	Alta	No cumple
R26	Transversal	i18n	Media	Cumple parcialmente
R27	Transversal	Dark/light	Media	Cumple parcialmente
R28	Calidad	Tests backend	Alta	Cumple parcialmente

6. Cumplimiento por modulos

Modulo	Estado	Evidencia	Diagnostico
Dashboard y KPIs	Parcial	services/dashboard.py	KPIs reales desde Firestore; faltan /dashboard/kpis, /dashboard/alerts, SLA medido y ranking formal.
CRM 360	Parcial	api/clientes.py	CRUD, busqueda simple e import CSV; faltan BANT, compras, tickets, PDF y auditoria especifica BANT.
Visitas	Parcial bajo	models/comercial.py	Interacciones basicas; faltan GPS, check-in/out, adjuntos, Calendar y Meet.
Propuestas	Parcial	services/comercial.py	Calculo descuento/total; faltan catalogo, impuestos, PDF, versiones y motivo perdida.
Pipeline	Parcial	api/comercial.py	Lista y cambios de etapa; falta historial, filtros completos y endpoint funnel oficial.

Modulo	Estado	Evidencia	Diagnostico
RAG	No cumple	InteligenciaMercado.jsx	Pantalla marcada como no operativa; sin Vertex/Gemini.
Competencia	Parcial/Fase 2	services/competencia.py	Repositorio lectura; writableFromUi false, sin flujo movil ni CRUD.
Reportes	No cumple	Sin endpoints export	No hay XLSX/PDF ni reportes formales.

7. Evaluacion de roles y permisos

- Implementado: validacion de token, lectura de users/{uid}, rol normalizado, bloqueo de usuario inactivo y jerarquia admin > supervisor > vendedor.
- Implementado: vendedores filtrados por vendedorUid/ownerUid en clientes y registros comerciales.
- Implementado parcial: supervisor solo puede aprobar propuestas, no editar montos/titulos/notas.
- Brecha: RBAC no es granular por recurso/accion; no existen claims personalizados ni matriz declarativa de permisos.
- Brecha: reglas Firestore no modelan UID/rol; bloquean todo acceso directo, por lo que el sistema depende completamente del backend.
- Brecha: varias rutas frontend usan ProtectedRoute generico sin minimumRole especifico para vistas de equipo/competencia.

8. Evaluacion de API

Endpoint oficial	Endpoint real	Estado
POST /auth/login email/password	POST /auth/login con Bearer Firebase	Desalineado en contrato; correcto para Firebase
GET /dashboard/kpis	/dashboard/vendedor, /dashboard/supervisor	Desalineado
GET /dashboard/alerts	No existe	No cumple
GET /opportunities	/oportunidades	Desalineado por idioma/nombre
GET /opportunities/{id}	/oportunidades/{id}/detalle	Desalineado
GET /pipeline/funnel	Incluido en dashboard	Parcial
GET /equipo/matriz	No endpoint dedicado	No cumple
GET /proyecciones	No endpoint dedicado	No cumple
GET /competencia/precios	/competencia/repository	Parcial/desalineado
GET /usuarios	/users/	Desalineado
POST /usuarios	No existe	No cumple
PUT /usuarios/{id}	PATCH /users/{uid}	Parcial
DELETE /usuarios/{id}	No existe; se desactiva	Parcial

Los errores estandar con error, codigo, detalles y timestamp si estan implementados en app/core/errors.py.

9. Evaluacion de no funcionales y estandares transversales

Area	Estado	Comentario
Seguridad auth	Parcial solido	Firebase Admin + Bearer token.
CORS	Parcial	Validacion anti wildcard en produccion.
Headers seguridad	Parcial	CSP, X-Frame-Options, nosniff y Permissions-Policy.

Area	Estado	Comentario
Rate limit	Parcial	Middleware en memoria; no distribuido.
Auditoria	Parcial	audit_logs sin IP/origen/inmutabilidad.
Multi-tenancy	No cumple	No hay clientId/tenant obligatorio.
Feature gating	No cumple	No hay plan/tier ni 402/403 comercial.
i18n	Parcial	Diccionario manual y traduccion DOM.
Dark/light	Parcial	Preferencia de usuario persistida.
Performance	No evaluable	Sin benchmarks p95/dashboard/RAG.
Observabilidad	No cumple	Sin Cloud Logging/Monitoring configurado.
CI/CD	No cumple/parcial	Sin cloudbuild.yaml; Vercel parcial.

10. Inconsistencias entre documentacion y codigo

- La especificacion oficial exige Vue 3 + Pinia, pero el codigo usa React + Vite.
- README menciona mobile como parte de la estructura, pero la carpeta mobile esta vacia y reservada para Fase 2.
- docs/architecture.md mantiene una referencia obsoleta a CRM mock, aunque el codigo actual conecta clientes por API.
- La API oficial esperada usa /opportunities, /usuarios y /dashboard/kpis; la real usa /oportunidades, /users y /dashboard/vendedor.
- Inteligencia de mercado, calendario y mapa aparecen en UI, pero estan marcados explicitamente como no operativos.

11. Riesgos actuales del proyecto

Riesgo	Severidad	Confirmacion
Alcance oficial excede MVP real	Critica	Multiples modulos Fase 2 ausentes.
Desalineacion Vue vs React	Alta	Dependencias y codigo React.
Sin mobile real	Alta	mobile vacio.
Sin ERP/SAP	Alta	No hay adaptadores.
Sin Calendar/Meet	Media/Alta	Modal no operativo.
Sin RAG	Media/Alta	Pantalla no operativa.
Sin multi-tenancy	Alta	No tenant isolation.
Sin historial de oportunidades/propuestas	Alta	No subcolecciones historial/versiones.
Sin evidencia de UAT/PR aprobado	Media	No verificable desde codigo.

12. Que ya esta

- Backend FastAPI modular.
- Firebase Auth + Firebase Admin.
- Firestore como persistencia via backend.
- CRUD clientes e importacion CSV.
- Interacciones, oportunidades y propuestas basicas.
- Dashboard vendedor/supervisor parcial.

- Administracion parcial de usuarios.
- Preferencias de idioma/tema.
- Auditoria tecnica basica.
- Tests backend, lint y build limpios.

13. Que esta parcial

- CRM 360: existe CRUD, falta 360 real.
- Dashboard: metricas reales, faltan alertas oficiales y SLA.
- Pipeline: existe lista/etapas, falta historial y funnel endpoint.
- Propuestas: existe calculo basico, falta PDF/versiones/motivo perdida/productos/impuestos.
- Inteligencia competitiva: lectura parcial, sin edicion ni flujo movil.
- Auditoria: logs basicos, no completos ni inmutables.
- RBAC: roles jerarquicos, no permisos granulares.

14. Que falta

- Vue 3 + Pinia si la especificacion oficial no permite React.
- App Flutter real.
- RAG Vertex/Gemini con citas.
- ERP/SAP y Google Calendar/Meet.
- Cloud Storage funcional.
- Reportes XLSX/PDF.
- Tickets, catalogo real, metas persistidas, BANT e historial de compras.
- Historial de etapas, versionado de propuestas y motivo de perdida obligatorio.
- Multi-tenancy, feature gating, Cloud Build, observabilidad y manual de usuario con capturas reales.

15. Que hay que pulir

- Quitar o bloquear completamente TemporaryRoleSwitcher antes de produccion.
- Alinear nombres de endpoints con contrato oficial o actualizar contrato.
- Mover vistas no operativas detras de feature flags.
- Agregar paginacion real por cursor Firestore; hoy se hacen lecturas amplias y limites en memoria.
- Completar permisos frontend por rutas supervisor/admin.
- Corregir documentacion obsoleta y agregar pruebas frontend/E2E.

16. Que cumple con el cliente

- Demo funcional web de login Google.
- Sesion protegida y sincronizacion de usuario.
- Gestion basica de clientes.
- Importacion CSV backend.

- Flujo comercial basico.
- Dashboard comercial parcial.
- Gestion parcial de usuarios/roles.
- Tema claro/oscuro e idioma basico.

17. Que no cumple con el cliente

- Stack web esperado Vue/Pinia.
- App movil Flutter.
- RAG operativo.
- ERP/SAP.
- Calendar/Meet.
- CRM 360 completo.
- Reportes/exportaciones.
- Inteligencia competitiva operativa.
- Modelo Firestore completo, multi-tenancy, feature gating, auditoria completa y produccion GCP verificable.

18. Backlog priorizado de cierre

Prioridad	Item	Criterio de aceptacion	Responsable	Estimacion
P0	Decidir React vs Vue oficial	Acta tecnica: mantener React o migrar.	Arquitectura/Cliente	S
P0	Completar contrato API MVP	Endpoints documentados coinciden con backend.	Backend	M
P0	Cerrar permisos por rol	Rutas frontend/backend alineadas a matriz.	Fullstack	M
P0	Historial oportunidades	Cada cambio de etapa escribe historial.	Backend	M
P0	Motivo perdida obligatorio	Estado perdido exige motivo persistido.	Backend/Frontend	S
P0	Propuestas MVP completas	Productos, impuestos basicos y estados oficiales.	Fullstack	L
P0	Dashboard alerts	/dashboard/alerts con links a registros.	Backend/Frontend	M
P0	Preparar UAT	Ambiente dev desplegado + checklist ejecutado.	Delivery/QA	M
P1	Firestore queries escalables	Filtros server-side/cursors, sin stream total.	Backend	M
P1	Export CSV/XLSX/PDF minimo	Cientes, oportunidades y propuestas exportables.	Fullstack	L
P1	Auditoria ampliada	IP/origen/user/action/result en eventos criticos.	Backend	M
P1	Observabilidad	Logging estructurado y metricas basicas.	DevOps	M
P1	Cloud Run/Cloud Build	Pipeline reproducible.	DevOps	M
P2	RAG Fase 2	Chat con citas y corpus administrable.	IA/Backend	XL
P2	ERP/SAP	Adaptador real con pedido/factura.	Integraciones	XL
P2	Calendar/Meet	Crear, actualizar y eliminar eventos.	Backend	L
P2	Flutter	App movil con offline basico.	Mobile	XL
P2	Multi-tenancy	clientId obligatorio y aislado.	Arquitectura/Backend	XL
P2	Feature gating	Plan/tier backend + UI.	Fullstack	L

19. Recomendacion final sobre estado del sistema

Recomendacion: mantener el repositorio como MVP web React acotado solo si el cliente aprueba formalmente esa desviacion. Si la especificacion oficial es vinculante, se requiere una fase de realineacion mayor antes de QA formal. En su estado actual, el sistema debe presentarse como demo/Development, no como producto listo para UAT o produccion.

Conclusion operativa: no avanzar a produccion hasta cerrar P0, desplegar ambiente Development verificable, ejecutar UAT, completar permisos, corregir contrato API y resolver la decision de stack.